

CEH v13

MODULE 01

Introduction to Ethical Hacking

Conceptual • Exam-Focused • Practical Notes

Certified Ethical Hacker — Study Guide

TABLE OF CONTENTS

1. Module Overview	3
2. Information Security Fundamentals	3
2.1 Information Security	3
2.2 The CIA Triad	3
2.3 Authentication, Authorization, Accountability & Non-Repudiation	4
3. Cybersecurity Concepts	5
4. Types of Hackers	6
5. Ethical Hacking	7
5.1 Ethical Hacking vs Malicious Hacking	7
6. Types of Attacks	8
7. Attack Vectors	9
8. Vulnerability Assessment (VA)	9
9. Penetration Testing (PT)	10
10. Vulnerability Assessment vs Penetration Testing	10
11. Ethical Hacking Methodology	11
12. Laws and Ethics	12
13. Tools Used	13
14. Commands Required	13
15. Diagrams & Practical Concepts Summary	13
16. CEH Exam Points — Consolidated	13
17. Common Confusions — Consolidated	14
18. Module 01 Quick Revision	14
19. Self-Test MCQs	15

1. Module Overview

Module 01 of CEH v13 lays the conceptual foundation for the entire ethical hacking course. Before learning tools and techniques, a CEH candidate must clearly understand what information security means, how attackers think, what separates ethical hacking from malicious hacking, and the structured methodology professionals follow when authorized to test a system.

This module introduces the vocabulary, classifications, and processes that every later module builds upon. A strong grip on Module 01 terminology is essential — many CEH exam questions test precise definitions and the ability to distinguish closely related terms (e.g. threat vs. vulnerability, VA vs. PT, authentication vs. authorization).

CEH EXAM POINT — Module 01 is definition-heavy. Expect direct questions on terminology, classifications, and the 5-phase methodology.

What this module covers:

- Core information security concepts and the CIA Triad
- Key cybersecurity terms: threat, vulnerability, exploit, risk, attack
- Classification of hackers and their motivations
- Ethical hacking: definition, scope, and responsibilities
- Types of attacks and attack vectors
- Vulnerability Assessment and Penetration Testing
- The 5-phase Ethical Hacking Methodology
- Information security laws, standards, and ethics

2. Information Security Fundamentals

2.1 Information Security

Definition

Information Security (InfoSec) is the practice of protecting information and information systems from unauthorized access, use, disclosure, disruption, modification, or destruction.

Concept

It is not just about technology — it combines people, processes, and technology to keep data safe throughout its lifecycle: creation, storage, transmission, and disposal.

Why It Matters

Organizations run on data. A single breach can cause financial loss, legal liability, reputational damage, and loss of customer trust. InfoSec is the umbrella discipline that ethical hacking supports and validates.

CEH EXAM POINT — Information Security = People + Process + Technology working together, not just firewalls or antivirus.

2.2 The CIA Triad

Definition

The CIA Triad is the foundational model of information security, consisting of three core principles: **Confidentiality**, **Integrity**, and **Availability**.

The CIA Triad — Foundation of Information Security

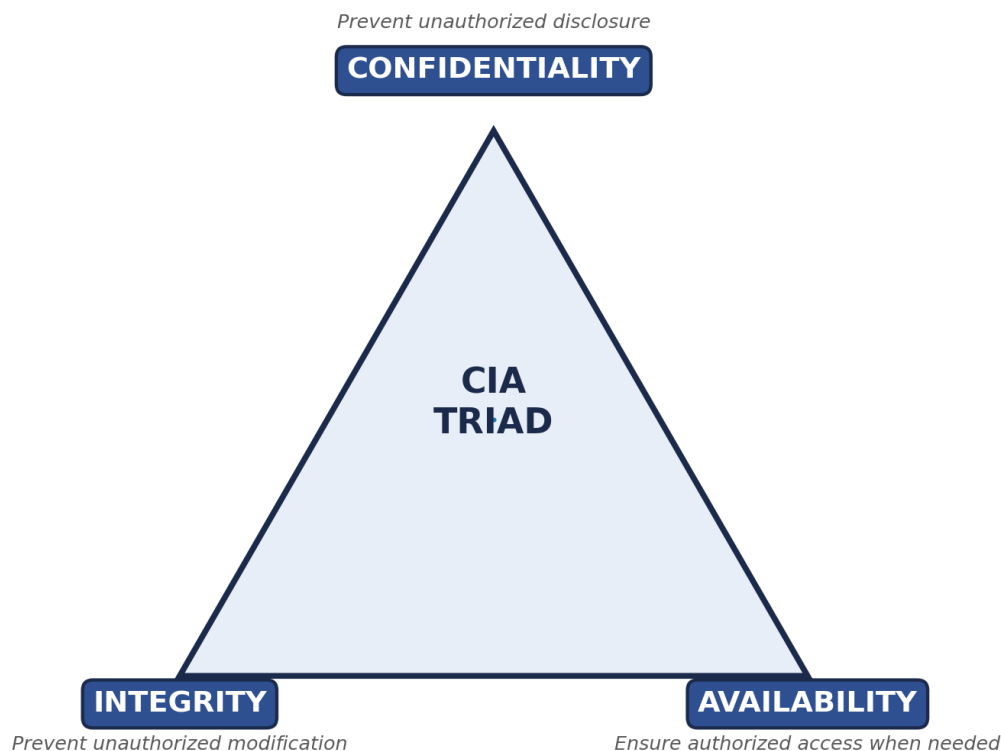


Figure 1 — The CIA Triad and its three protective goals

Confidentiality

Ensures information is accessible only to those authorized to view it. Achieved through encryption, access controls, and classification policies.

Integrity

Ensures information remains accurate and unaltered except by authorized action. Achieved through hashing, checksums, digital signatures, and version control.

Availability

Ensures information and systems are accessible to authorized users whenever needed. Achieved through redundancy, backups, load balancing, and DDoS protection.

Example

A hospital database: **Confidentiality** stops unauthorized staff from viewing patient records; **Integrity** ensures a patient's blood type is never silently altered; **Availability** ensures doctors can access records during an emergency.

CEH EXAM POINT — Any attack ultimately violates at least one leg of the CIA Triad — this is the base model used to classify attack impact.

2.3 Authentication, Authorization, Accountability & Non-Repudiation

Term	Definition	Simple Example
Authentication	Verifying WHO a user is (identity check).	Entering a password to log in.

Term	Definition	Simple Example
Authorization	Verifying WHAT an authenticated user is allowed to do.	A normal user cannot access admin settings.
Accountability	Tracking actions back to the responsible user (audit trail).	Log files record who deleted a file.
Non-Repudiation	Preventing a user from denying an action they performed.	Digital signatures on a signed contract.

COMMON CONFUSION — Authentication vs Authorization — Authentication confirms identity ('who are you'); Authorization confirms permission ('what can you do'). Authentication always happens first.

3. Cybersecurity Concepts

These terms describe the chain of events that leads from a weakness in a system to actual harm. Understanding their exact relationship is one of the most heavily tested areas in Module 01.

Security Concept Relationship Chain

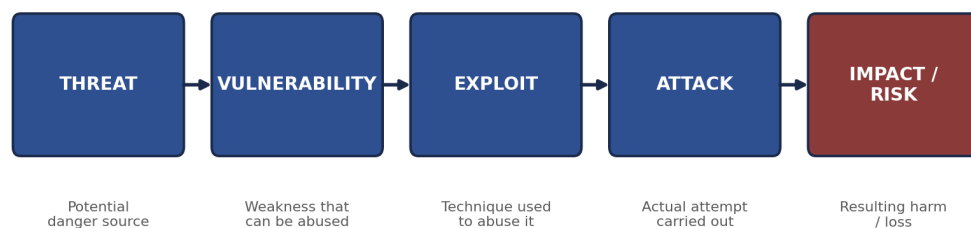


Figure 2 — How a Threat becomes Risk through Vulnerability, Exploit, and Attack

Term	Definition
Threat	Any potential danger — a person, event, or circumstance — that could exploit a vulnerability and cause harm.
Vulnerability	A weakness or gap in a system's design, implementation, or configuration that can be exploited.
Exploit	A defined technique, piece of code, or method used to take advantage of a vulnerability.
Attack	The actual act of attempting to exploit a vulnerability against a system.
Attack Vector	The specific path or means by which an attacker gains access to a target (e.g. email, USB, web app).
Attack Surface	The total sum of all possible points where an attacker could try to enter or extract data.
Risk	The potential for loss or damage when a threat exploits a vulnerability — often expressed as Risk = Threat × Vulnerability × Impact.
Security Controls	Safeguards (technical, administrative, or physical) put in place to reduce risk.

Example — Practical Walkthrough

Scenario: A company runs an outdated, unpatched web server.

- **Threat:** An external attacker scanning the internet for vulnerable servers.
- **Vulnerability:** Unpatched software with a known flaw.

- **Exploit:** A publicly available exploit code targeting that flaw.
- **Attack:** The attacker runs the exploit against the server.
- **Impact:** Unauthorized access and possible data compromise.
- **Risk:** Financial loss, regulatory penalty, and reputational damage.

COMMON CONFUSION — Threat vs Vulnerability: A threat is the potential danger (the attacker/event); a vulnerability is the weakness that danger can exploit. No vulnerability = threat cannot succeed.

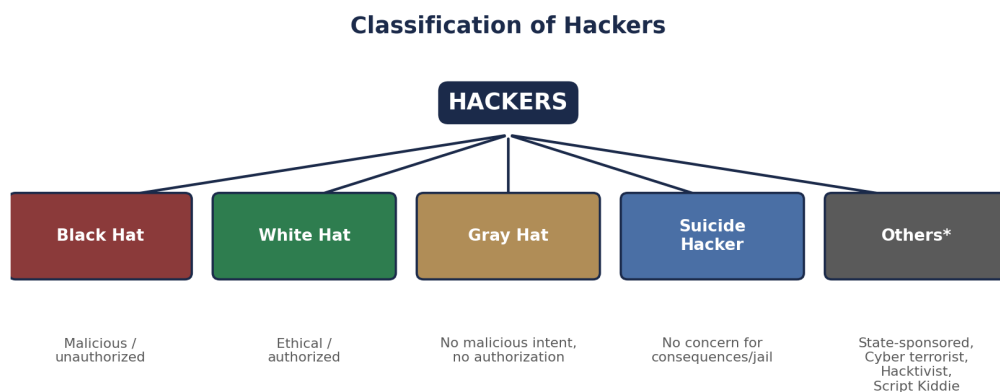
Vulnerability vs Exploit: A vulnerability is the open door; an exploit is the specific key/tool used to walk through it.

Attack Vector vs Attack Surface: An attack vector is ONE path of entry (e.g. phishing email). The attack surface is the ENTIRE collection of all such possible paths across a system.

CEH EXAM POINT — Risk cannot exist without both a Threat AND a Vulnerability being present at the same time.

4. Types of Hackers

Hackers are classified based on their intent, authorization, and the legality of their actions.



**Others include State-Sponsored Hackers, Cyber Terrorists, Hacktivists, and Script Kiddies*

Figure 3 — Classification of Hackers by Intent and Authorization

Type	Definition	Motivation	Example
Black Hat	Hackers who violate security for personal or malicious gain, without authorization.	Financial gain, sabotage, malice	Deploying ransomware against a company
White Hat	Security professionals who hack with proper authorization to find and fix flaws.	Improving security, employment	A penetration tester hired to test a bank's app
Gray Hat	Operate between ethical and unethical; may find flaws without authorization but don't exploit maliciously.	Curiosity, recognition	Reporting a bug found without permission

Type	Definition	Motivation	Example
Suicide Hacker	Hackers who attack critical infrastructure without regard for being caught or punished.	Ideology, activism, disregard for consequences	Attacking systems knowing arrest is certain
Script Kiddie	Unskilled individuals who use existing tools/scripts made by others.	Attention, fun, low skill	Running a downloaded DDoS tool
State-Sponsored Hacker	Hackers employed by governments to attack other nations/entities.	Political/military advantage	Nation-state cyber-espionage campaign
Hactivist	Hackers driven by political or social causes.	Activism, protest	Defacing a website to protest a policy
Cyber Terrorist	Attackers aiming to cause fear, chaos, or damage for ideological reasons.	Ideology, mass disruption	Targeting a power grid to spread panic

CEH EXAM POINT — White Hat = authorized. Black Hat = unauthorized + malicious. Gray Hat = unauthorized but not malicious. Authorization is the key differentiator tested on the exam.

5. Ethical Hacking

Definition

Ethical Hacking is the authorized practice of bypassing system security to identify potential data breaches and threats, performed with the explicit permission of the system owner.

Objectives

- Identify vulnerabilities before malicious hackers do
- Assess the effectiveness of existing security controls
- Provide actionable recommendations to strengthen defenses
- Help the organization comply with regulatory/security standards

Role of the Ethical Hacker

An ethical hacker (also called a White Hat or CEH-certified professional) thinks and acts like an attacker but works strictly within a legally defined scope, using the same tools and techniques as malicious hackers — for a defensive purpose.

Ethical Responsibilities

- Obtain written authorization before any testing
- Stay within the agreed scope of engagement
- Maintain confidentiality of discovered data
- Report all findings honestly and completely
- Do not cause unnecessary damage or disruption

5.1 Ethical Hacking vs Malicious Hacking

Aspect	Ethical Hacking	Malicious Hacking
Authorization	Explicit, written permission obtained	No authorization — illegal
Intent	Improve and strengthen security	Personal gain, damage, theft
Scope	Bound by a defined Rules of Engagement	No boundaries or limits

Aspect	Ethical Hacking	Malicious Hacking
Reporting	Full disclosure to the organization	Findings kept secret or sold
Legality	Legal	Illegal

COMMON CONFUSION — **Ethical Hacking vs Malicious Hacking:** The techniques used can be identical — the difference is entirely defined by **authorization, intent, and legality**, not skill or tools.

CEH EXAM POINT — Without written authorization, even 'well-intentioned' hacking is illegal and NOT ethical hacking.

6. Types of Attacks

Attacks against a system are broadly classified based on where the underlying weakness lies.

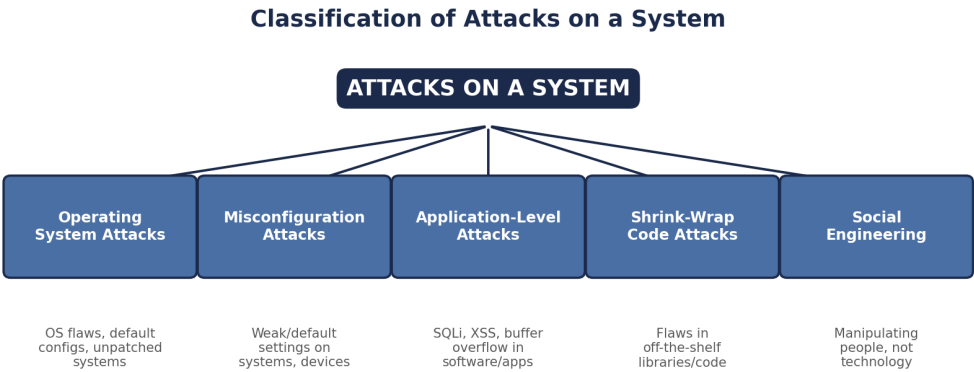


Figure 4 — Classification of Attacks on a System

Attack Category	Basic Concept	Example	Impact
Operating System Attacks	Exploiting flaws, default configurations, or unpatched components within an OS.	Exploiting an unpatched Windows service to gain SYSTEM-level access.	Full system compromise
Misconfiguration Attacks	Exploiting systems, devices, or applications left with weak or default security settings.	Accessing an admin panel still using default username/password.	Unauthorized access
Application-Level Attacks	Exploiting flaws in the code or logic of software applications.	SQL Injection to extract data from a login form.	Data theft, app compromise
Shrink-Wrap Code Attacks	Exploiting vulnerabilities in off-the-shelf libraries, frameworks, or code included by default.	Exploiting a known flaw in an unmodified open-source library.	Compromise via third-party code
Social Engineering	Manipulating people (not technology) into revealing information or performing actions.	A phishing email tricking an employee into revealing credentials.	Credential theft, initial access

CEH EXAM POINT — Social Engineering attacks target humans, not technical systems — this is why it is often the easiest and most common initial attack vector.

7. Attack Vectors

Definition

An attack vector is the specific path or method an attacker uses to gain unauthorized access to a target system or network.

Attack Vector: Path from Attacker to Target



Figure 5 — Common Attack Vectors from Attacker to Target System

Attack Vector	How It Works	Prevention Consideration
Phishing Email	Deceptive emails trick users into clicking malicious links or attachments.	User awareness training, email filtering
Malware / Unpatched Software	Malicious code exploits known software flaws to gain access.	Regular patching, antivirus/EDR
Weak Credentials	Guessable or reused passwords are brute-forced or stolen.	Strong password policy, MFA
Insider Threat	A trusted employee misuses legitimate access.	Least privilege, monitoring, audits
Cloud Misconfiguration	Improperly secured cloud storage or services expose data.	Configuration audits, access reviews

CEH EXAM POINT — An organization can reduce its Attack Surface by closing unused ports, disabling unused services, and patching — thereby reducing the number of available Attack Vectors.

8. Vulnerability Assessment (VA)

Definition

Vulnerability Assessment is a systematic process of identifying, quantifying, and prioritizing vulnerabilities in a system, without exploiting them.

Purpose

To produce a comprehensive list of known weaknesses so the organization can plan remediation, before an attacker can exploit them.

Process

- **Identification** — Scan systems/networks to discover potential vulnerabilities
- **Analysis** — Determine the nature, cause, and severity of each finding
- **Prioritization** — Rank vulnerabilities by risk level (e.g. Critical, High, Medium, Low)
- **Reporting** — Document all findings clearly for stakeholders
- **Remediation** — Apply patches or fixes to eliminate/reduce the vulnerabilities

CEH EXAM POINT — Vulnerability Assessment is broad and automated — it lists what **COULD** be exploited, but does not exploit it.

9. Penetration Testing (PT)

Definition

Penetration Testing is an authorized, simulated cyberattack against a system to evaluate its security by actively and safely exploiting vulnerabilities.

Purpose

To prove real-world exploitability and business impact of vulnerabilities — going beyond a simple list to demonstrate what an attacker could actually achieve.

Process

- **Planning & Scoping** — Define rules of engagement and targets
- **Controlled Exploitation** — Actively attempt to exploit discovered vulnerabilities
- **Validation** — Confirm real impact (e.g. data access, privilege escalation)
- **Reporting** — Provide proof-of-concept evidence and remediation guidance

CEH EXAM POINT — Penetration Testing always requires explicit written authorization defining scope, timing, and rules of engagement.

10. Vulnerability Assessment vs Penetration Testing

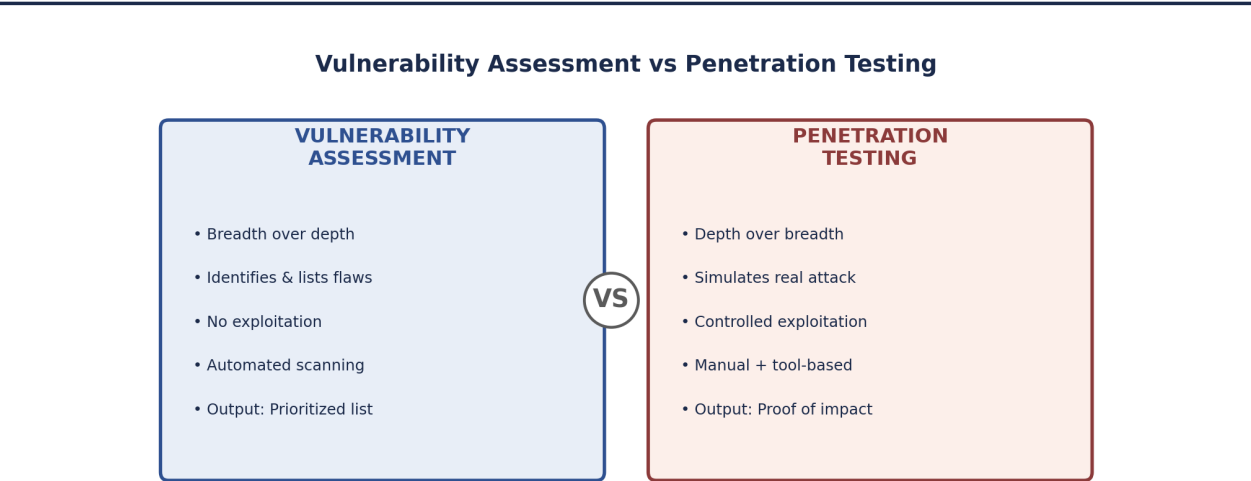


Figure 6 — VA vs PT: Key Differences at a Glance

Aspect	Vulnerability Assessment	Penetration Testing
Purpose	Identify and list known vulnerabilities	Prove exploitability and real-world impact

Aspect	Vulnerability Assessment	Penetration Testing
Approach	Broad, automated scanning	Focused, manual + tool-based testing
Exploitation	No active exploitation	Controlled, authorized exploitation
Depth	Breadth over depth	Depth over breadth
Output	Prioritized vulnerability list	Proof-of-concept report with business impact
Objective	Reduce number of weaknesses	Validate defenses against real attack scenarios

COMMON CONFUSION — VA vs PT: VA answers 'What vulnerabilities exist?' — PT answers 'Can they actually be exploited, and what happens if they are?' PT normally follows VA in a mature security program.

11. Ethical Hacking Methodology

CEH defines a structured, repeatable 5-phase methodology that mirrors the approach a real attacker would take — performed under authorization for defensive purposes.

Ethical Hacking Methodology (CEH Phases)



Reporting is performed throughout / after the methodology (documentation of findings)

Figure 7 — The 5-Phase Ethical Hacking Methodology

1. Reconnaissance

Purpose: Gather as much information as possible about the target before any direct interaction.

Main Activities: Passive: OSINT, WHOIS lookups, social media. Active: direct probing of the target.

Expected Result: A profile of the target's infrastructure, employees, and technologies.

Example: Searching LinkedIn and company websites for employee names and technologies used.

2. Scanning

Purpose: Actively probe the target to identify live systems, open ports, and services.

Main Activities: Port scanning, network mapping, vulnerability scanning.

Expected Result: A list of live hosts, open ports, and running services/versions.

Example: Using a port scanner to discover an open, outdated FTP service.

3. Gaining Access

Purpose: Exploit identified vulnerabilities to obtain unauthorized access to the system.

Main Activities: Exploiting a vulnerability, password cracking, or social engineering to gain entry.

Expected Result: Actual access to the system, application, or network.

Example: Using a known exploit to gain a shell on the vulnerable server.

4. Maintaining Access

Purpose: Retain access to the compromised system for further actions or persistence testing.

Main Activities: Installing backdoors, creating hidden accounts, using rootkits (in a controlled test).

Expected Result: Demonstrated ability to return to the system without repeating exploitation.

Example: Simulating how an attacker could keep long-term access undetected.

5. Clearing Tracks

Purpose: Remove evidence of the testing activity to simulate an attacker avoiding detection.

Main Activities: Clearing logs, hiding files, disabling alerts (documented for the client).

Expected Result: Demonstration of how a real attacker could evade detection/forensics.

Example: Clearing command history and log entries generated during testing.

CEH EXAM POINT — The 5 phases in exact order: Reconnaissance → Scanning → Gaining Access → Maintaining Access → Clearing Tracks. This sequence is a very common exam question.

COMMON CONFUSION — Reconnaissance vs Scanning: Reconnaissance is largely passive information gathering; Scanning is active, direct technical probing of the target's live systems.

12. Laws and Ethics

Ethical hacking only remains 'ethical' when it is conducted within strict legal and procedural boundaries. These principles apply throughout every phase of testing.

Authorization

Written, explicit permission from the system owner must be obtained before any testing begins. Testing without authorization is illegal, regardless of intent.

Scope

The specific systems, networks, and applications that may be tested — anything outside scope must not be touched.

Rules of Engagement (RoE)

A formal document defining testing boundaries: timing, techniques allowed/disallowed, emergency contacts, and communication protocol.

Privacy

Any sensitive or personal data encountered during testing must be handled confidentially and not disclosed or misused.

Responsible Disclosure

Vulnerabilities discovered must be reported privately to the organization first, giving them time to fix issues before any public disclosure.

Legal Limitations

Ethical hackers must comply with relevant cyber laws and regulations of the jurisdiction they operate in.

Ethical Responsibilities

Maintain integrity, avoid unnecessary damage, and always act in the best interest of the client organization.

CEH EXAM POINT — No authorization = no ethical hacking, no matter how good the intention. This is a core CEH principle tested repeatedly.

13. Tools Used

Module 01 is a conceptual foundation module. It introduces terminology, classifications, and methodology rather than hands-on tool usage.

No major practical tools are required for this module. Tool-based practicals begin from Module 02 (Footprinting and Reconnaissance) onward.

14. Commands Required

No major commands are required for this module. Module 01 focuses purely on concepts, classifications, and methodology.

15. Diagrams & Practical Concepts Summary

A quick index of every diagram in this document, for fast visual recall during revision:

Figure	Diagram	Concept Reinforced
Fig. 1	CIA Triad	Confidentiality, Integrity, Availability relationship
Fig. 2	Security Concept Chain	Threat → Vulnerability → Exploit → Attack → Risk
Fig. 3	Hacker Classification	Black/White/Gray Hat and other hacker types
Fig. 4	Attack Classification	OS, Misconfiguration, Application, Shrink-Wrap, Social Engineering
Fig. 5	Attack Vector	Paths an attacker uses to reach a target
Fig. 6	VA vs PT	Visual comparison of assessment vs testing
Fig. 7	Ethical Hacking Methodology	5-phase sequence of a controlled engagement

16. CEH Exam Points — Consolidated

- Information Security = People + Process + Technology, not just tools.
- CIA Triad: Confidentiality, Integrity, Availability — every attack violates at least one.
- Risk requires BOTH a Threat and a Vulnerability to exist simultaneously.
- Attack Vector = one path in; Attack Surface = all possible paths combined.
- White Hat = authorized; Black Hat = unauthorized + malicious; Gray Hat = unauthorized, not malicious.
- Ethical Hacking requires written authorization — without it, it is illegal.
- Social Engineering targets people, not technology.
- VA = broad, no exploitation. PT = focused, controlled exploitation.
- 5-Phase Methodology order: Reconnaissance → Scanning → Gaining Access → Maintaining Access → Clearing Tracks.
- Reconnaissance is largely passive; Scanning is active and technical.
- Rules of Engagement define the legal and technical boundaries of a penetration test.

- Responsible Disclosure means reporting privately to the organization before any public release.

17. Common Confusions — Consolidated

Authentication vs Authorization — Authentication = who you are. Authorization = what you can do.

Threat vs Vulnerability — Threat = potential danger. Vulnerability = the exploitable weakness.

Vulnerability vs Exploit — Vulnerability = the open door. Exploit = the tool/technique used to go through it.

Risk vs Vulnerability — Vulnerability is one input to Risk; Risk also factors in threat likelihood and impact.

Attack Vector vs Attack Surface — Vector = one entry path. Surface = total of all entry paths.

VA vs PT — VA lists weaknesses; PT proves and demonstrates exploitability.

Ethical Hacking vs Malicious Hacking — Same techniques — different authorization, intent, and legality.

18. Module 01 Quick Revision

MODULE 01 — QUICK REVISION (5–10 minute recap)

Core Definitions

- **InfoSec:** Protecting information via People + Process + Technology
- **CIA Triad:** Confidentiality, Integrity, Availability
- **Threat → Vulnerability → Exploit → Attack → Risk** (the security chain)
- **Attack Vector:** one path in | **Attack Surface:** all paths combined

Hacker Classification

- White Hat = authorized & ethical | Black Hat = unauthorized & malicious | Gray Hat = unauthorized, not malicious
- Suicide Hacker, Script Kiddie, State-Sponsored, Hacktivist, Cyber Terrorist — motivation-based types

Ethical Hacking

- Authorized, legal simulation of attacker techniques to strengthen security
- Requires: written authorization, defined scope, responsible disclosure

Attacks & Vectors

- Categories: OS Attacks, Misconfiguration, Application-Level, Shrink-Wrap Code, Social Engineering
- Vectors: phishing, malware, weak credentials, insider threat, cloud misconfiguration

VA vs PT

- VA = identify + list vulnerabilities (no exploitation, broad)
- PT = simulate real attack + exploit (controlled, deep, proves impact)

5-Phase Methodology

- Reconnaissance → Scanning → Gaining Access → Maintaining Access → Clearing Tracks

Laws & Ethics

- Authorization, Scope, Rules of Engagement, Privacy, Responsible Disclosure — all mandatory

19. Self-Test MCQs

15 CEH-style questions covering definitions, classifications, differences, and methodology from Module 01.

Q1. Which principle of the CIA Triad ensures that data is not altered by unauthorized users?

- A. Confidentiality
- B. Integrity
- C. Availability
- D. Accountability

Correct Answer: B

Explanation: Integrity ensures data accuracy and prevents unauthorized modification.

Q2. A hacker who has no authorization but does not have malicious intent is best classified as a:

- A. Black Hat
- B. White Hat
- C. Gray Hat
- D. Script Kiddie

Correct Answer: C

Explanation: Gray Hat hackers act without authorization but without malicious intent, unlike Black Hats.

Q3. What is the correct relationship between a Threat and a Vulnerability?

- A. A Threat is caused by a Vulnerability
- B. A Vulnerability is exploited by a Threat to cause Risk
- C. They are the same thing
- D. A Vulnerability always creates a Threat

Correct Answer: B

Explanation: A threat exploits a vulnerability; both must exist together for risk to materialize.

Q4. Which of these is an example of an Attack Vector?

- A. Total number of open ports on a server
- B. A phishing email used to deliver malware
- C. The organization's entire IT infrastructure
- D. A security policy document

Correct Answer: B

Explanation: A phishing email is one specific path (vector) an attacker uses to gain access.

Q5. What differentiates Ethical Hacking from Malicious Hacking?

- A. The tools used
- B. The operating system targeted
- C. Authorization, intent, and legality
- D. The hacker's technical skill level

Correct Answer: C

Explanation: The techniques can be identical; authorization, intent, and legality define ethical hacking.

Q6. Which phase of the Ethical Hacking Methodology involves actively probing for open ports and services?

- A. Reconnaissance
- B. Scanning
- C. Gaining Access
- D. Clearing Tracks

Correct Answer: B

Explanation: Scanning is the active technical phase that identifies live hosts, ports, and services.

Q7. What is the correct order of the CEH 5-phase methodology?

- A. Scanning → Reconnaissance → Gaining Access → Clearing Tracks → Maintaining Access
- B. Reconnaissance → Scanning → Gaining Access → Maintaining Access → Clearing Tracks
- C. Gaining Access → Reconnaissance → Scanning → Maintaining Access → Clearing Tracks
- D. Reconnaissance → Gaining Access → Scanning → Clearing Tracks → Maintaining Access

Correct Answer: B

Explanation: The methodology follows: Recon → Scan → Gain Access → Maintain Access → Clear Tracks.

Q8. Which best describes Vulnerability Assessment?

- A. Actively exploiting a system to prove impact
- B. Broadly identifying and listing known weaknesses without exploitation
- C. Only testing physical security
- D. A legal contract for testing

Correct Answer: B

Explanation: VA is broad and identifies/lists vulnerabilities without active exploitation.

Q9. Penetration Testing differs from Vulnerability Assessment mainly because it:

- A. Uses no tools at all
- B. Involves controlled, authorized exploitation to prove real-world impact
- C. Is always automated
- D. Never requires authorization

Correct Answer: B

Explanation: PT actively and safely exploits vulnerabilities to demonstrate real impact.

Q10. Which term refers to the total sum of all possible entry points into a system?

- A. Attack Vector
- B. Attack Surface
- C. Exploit
- D. Risk

Correct Answer: B

Explanation: Attack Surface is the complete collection of all possible attack vectors.

Q11. A company's web application is vulnerable to SQL Injection. This is an example of a/an:

- A. Operating System Attack
- B. Misconfiguration Attack
- C. Application-Level Attack
- D. Shrink-Wrap Code Attack

Correct Answer: C

Explanation: SQL Injection exploits flaws in application code/logic — an Application-Level Attack.

Q12. Which of the following is NOT part of an ethical hacker's responsibilities?

- A. Obtaining written authorization
- B. Staying within scope
- C. Publicly disclosing vulnerabilities immediately
- D. Reporting findings honestly

Correct Answer: C

Explanation: Ethical hackers follow Responsible Disclosure — reporting privately first, not immediate public disclosure.

Q13. Authentication is best defined as:

- A. Verifying what a user is allowed to do
- B. Verifying the identity of a user
- C. Tracking a user's actions
- D. Preventing a user from denying an action

Correct Answer: B

Explanation: Authentication verifies WHO the user is; Authorization defines WHAT they can do.

Q14. A Rules of Engagement (RoE) document primarily defines:

- A. The salary of the ethical hacker
- B. The scope, boundaries, and rules of a penetration test
- C. The marketing plan of the company
- D. The programming language to be used

Correct Answer: B

Explanation: RoE formally defines testing scope, timing, allowed techniques, and communication protocols.

Q15. Which hacker type is most likely to be employed directly by a government for cyber-espionage?

- A. Script Kiddie
- B. State-Sponsored Hacker
- C. Gray Hat
- D. Suicide Hacker

Correct Answer: B

Explanation: State-Sponsored Hackers work on behalf of governments for political/military objectives.

End of CEH v13 — Module 01 Study Notes